RELATÓRIO TÉCNICO: DEVSECOPS AVANÇADO Tema: DAST, Privacidade de Dados e Supply Chain Security

1. Introdução à Arquitetura Open-Source A integração de segurança em esteiras de CI/CD (DevSecOps) não exige necessariamente ferramentas corporativas de alto custo. É plenamente possível alcançar um nível profissional de maturidade utilizando um ecossistema 100% open-source e gratuito. Ao combinar o GitHub Actions com ferramentas consolidadas pela comunidade, nossa arquitetura adota a cultura de "Shift-Left" (antecipação de testes). Isso garante que o código seja inspecionado, executado e validado em ambientes isolados a cada commit ou Pull Request, impedindo que falhas cheguem à produção.

2. Descritivo Técnico das Ferramentas Para cobrir as principais frentes de segurança, a esteira foi dividida em três pilares:

- **OWASP ZAP (DAST):** Responsável pelos Testes Dinâmicos. A esteira compila a aplicação, sobe um banco PostgreSQL em background e coloca a API no ar (localhost). O ZAP então ataca a aplicação "viva", procurando falhas exploráveis como Injeções, ausência de headers de segurança e XSS, bloqueando o build (exit-code 1) se algo crítico for exposto no tráfego.
- **Bearer:** Uma ferramenta de SAST especializada em Privacidade e Segurança de Dados. Ela atua diretamente no código-fonte buscando vulnerabilidades lógicas ligadas à LGPD, como hardcoding de senhas, falta de sanitização de dados sensíveis e vazamento de Informações Pessoalmente Identificáveis (PII).
- **Trivy (SBOM):** Focado na segurança da Cadeia de Suprimentos. O Trivy rastreia e lista todos os pacotes, bibliotecas e dependências empacotadas pela aplicação.

3. Integração com os Requisitos do Projeto A segurança da informação e a privacidade andam de mãos dadas com a LGPD. Ao configurar o **Bearer**, garantimos que o código não contenha fluxos que exponham dados sensíveis dos clientes de forma não intencional. Paralelamente, a geração do **SBOM pelo Trivy** no padrão internacional *CycloneDX* funciona como uma "tabela nutricional" do nosso software. Em caso de vulnerabilidades recém-descobertas no mercado (como o caso do Log4j), o artefato SBOM permite que nossos stakeholders saibam imediatamente se o software final entregue contém a biblioteca comprometida, facilitando auditorias de conformidade e resposta rápida a incidentes.

4. Evidências de Funcionamento (Prints)

Figura 1: Execução com sucesso da esteira de segurança (Job Green).

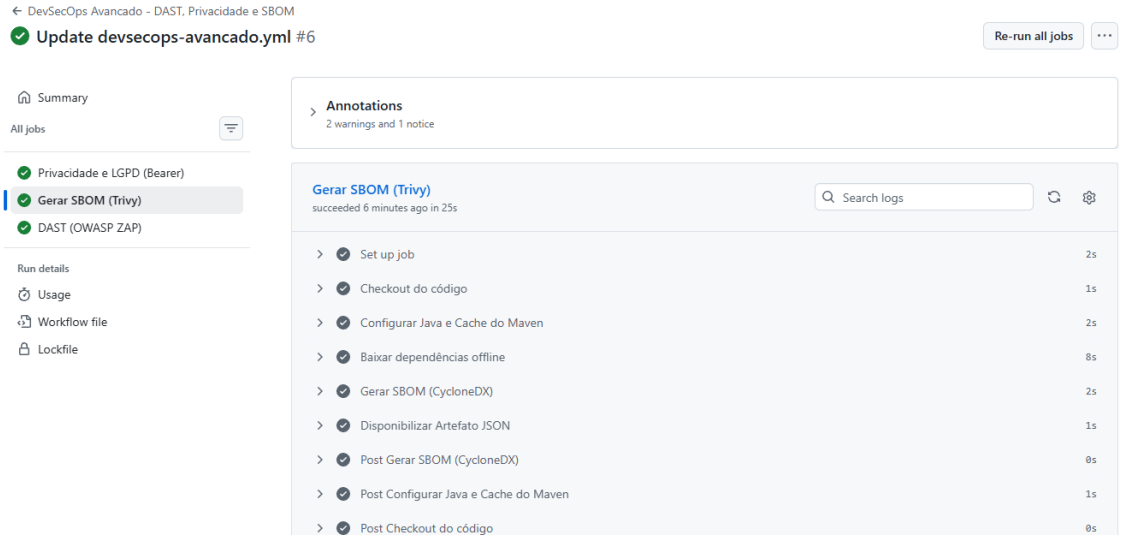


Figura 2: Artefato SBOM gerado e disponibilizado para download.

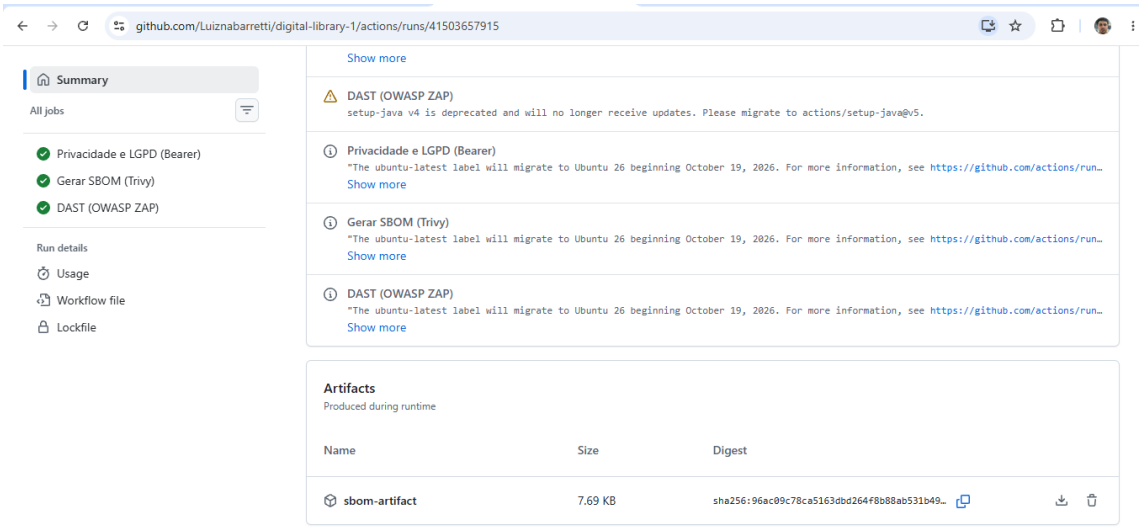


Figura 3: Demonstração do bloqueio do Pull Request ao detectar vulnerabilidades.

